

AutoTraq Backend API

Test Report

Tester: Gus

Date: March 16, 2026

Environment: Railway (Production DB)

Scope: Full backend API endpoint testing

Executive Summary

76 total tests were executed across all backend API endpoints. 60 passed, 15 failed, and 1 warning was flagged. The application is largely stable with strong authentication, CRUD operations, security controls, and audit functionality.

However, 4 real bugs were identified that need engineering attention, most critically a 48-second response time on the inventory on-hand endpoint.

Overall Pass Rate: 79% (60/76)

What's Working Well

Authentication & Authorization

- Login, token validation, role-based access, password change, and registration all function correctly
- Invalid credentials, missing fields, and empty bodies return proper validation errors
- JWT middleware correctly rejects missing/invalid tokens
- Role-based access control blocks manager accounts from admin-only endpoints
- SQL injection attempts handled safely

Parts Management

- Full CRUD lifecycle works (create, read, delete)
- Pagination with limit parameter works correctly
- Search and condition filtering work
- Validation catches missing fields, oversized strings, and negative prices
- Concurrent requests handled without crashes

Vehicles Management

- Full CRUD lifecycle works (create, read, update, delete)
- Duplicate vehicle protection works
- Pagination works correctly

Inventory System

- Storage locations can be created and listed
- Receive, correct, and return stock operations work (using qty field name)
- Top movers and dead stock endpoints respond correctly

Other Systems

- SKU code lookups (make, model, system, component) all work
- CSV export produces valid data with proper headers
- Audit log records all operations with correct structure
- Notifications, advanced search, parts hierarchy, and image delivery all work
- CORS configured correctly; unknown routes return clean 404 JSON

Performance (Passing)

Endpoint	Response Time	Status
GET /api/parts	0.56s	PASS
GET /api/vehicles	0.35s	PASS
GET /api/audit	0.18s	PASS

Bugs Found (Verified Against Source Code)

CRITICAL: Inventory On-Hand Query Takes 48 Seconds

Endpoint	GET /api/inventory/on-hand
Expected	Response under 2 seconds
Actual	48.26 seconds
Root Cause	N+1 query pattern in inventory.service.ts. For each grouped row, 2 separate DB lookups (part + location) run inside a loop, generating hundreds of queries.
Fix	Replace per-row findUnique calls with batch findMany queries, then join in memory.

HIGH: Malformed JSON Returns 500 Instead of 400

Endpoint	POST /api/parts (with malformed JSON body)
Expected	400 Bad Request with validation error
Actual	500 Internal Server Error
Root Cause	Global error handler in error.middleware.ts does not check for SyntaxError from Express JSON parser. All unhandled errors return 500.
Fix	Add SyntaxError check: if type is entity.parse.failed, return 400 validation error.

MEDIUM: Cannot Update Part Price

Endpoint	PUT /api/parts/:id
Expected	Sending retailPriceCents should update price
Actual	Price silently stripped - remains null after update
Root Cause	updatePartSchema in parts.schema.ts only allows sku, name, description, condition, minStock, costCents. retailPriceCents is not in the Zod schema.
Fix	Add retailPriceCents, isOem, and partType to the update schema.

MEDIUM: Invalid Image ID Returns 500 Instead of 404

Endpoint	GET /api/images/:id (with non-numeric ID)
Expected	400 Bad Request or 404 Not Found
Actual	500 Internal Server Error
Root Cause	images.routes.ts missing validateParams(idParamSchema) middleware. parseInt returns NaN, Prisma throws, caught as generic 500.

Fix	Add validateParams(idParamSchema) middleware to image routes.
------------	---

Not Bugs — API Design Differences

These items were flagged as failures but are actually working as designed:

Test	Why It's Not a Bug
Parts pagination uses page not offset	API expects ?page=2&limit=10, not ?offset=10. Documentation gap.
/vehicles/makes requires year	Intentional - makes are filtered per-year in the controller.
/vehicles/models requires year + make	Intentional - models scoped to both year and make.
/inventory/history returns aggregated data	By design - provides daily totals for charts. Use /events for individual records.
SKU generate rejects TOY	API expects full make name (Toyota), not the abbreviation.
Inventory uses qty not quantity	Field naming choice. Could be improved with documentation.
Request fulfill requires location	By design - items must have location assigned before fulfillment.

Recommendations

1. **Fix the 4 real bugs** listed above, prioritizing the inventory on-hand performance issue
2. **Improve API documentation** — several failures were caused by unclear field names (qty vs quantity, page vs offset)
3. **Add input validation middleware** to all routes accepting path parameters
4. **Add JSON parse error handling** to the global error middleware

Test Score Summary

Category	Passed	Failed	Total
Health	3	0	3
Auth	10	0	10
Parts	10	3	13
Vehicles	6	3	9
Inventory	10	5	15
Requests	3	2	5
SKU	4	1	5
CSV	4	0	4
Audit	4	0	4

Other APIs	8	0	8
Security/Edge Cases	5	1	6
Performance	3	1	4
Total	60	16	76